# PLAN DE CONTINUIDAD

GRC Corporativo

# PLAN DE CONTINUIDAD DE NEGOCIO TIC

## Plan de Continuidad TIC (PCTIC)

Incluye Análisis de Impacto en el Negocio (BIA)

# XYZ S.L.

Sector logístico — Envío, recepción y almacenamiento de paquetería

| Campo | Detalle |
|---|---|
| Fecha de elaboración | Marzo de 2026 |
| Responsable de elaboración | Marta López (CISO / Responsable de Seguridad) |
| Revisado por | Juan Pérez (Responsable de IT) |
| Aprobado por | Gerencia General — XYZ S.L. |
| Versión del documento | 1.0 |
| Clasificación | USO INTERNO — CONFIDENCIAL |

*Este documento ha sido elaborado tomando como marco de referencia los informes de seguridad previos de XYZ S.L.: Políticas de Seguridad de la Información (PSI_XYZ_v1.1), Análisis de Riesgos (Informe_AR_XYZ_v1.0), Plan Director de Seguridad (PDS_XYZ_v1.0), Plan de Respuesta ante Incidentes (PRI_XYZ_v1.0), Auditoría ISO 27001 y Auditoría ENS. El Plan de Continuidad TIC completa el cuerpo normativo de seguridad de la organización cubriendo la brecha identificada en el control A17.1.1 de la auditoría ISO 27001.*

# Control de Versiones

| Versión | Fecha | Autor/a | Descripción del cambio |
|---|---|---|---|
| 1.0 | Marzo 2026 | Marta López (CISO) | Versión inicial del Plan de Continuidad TIC con BIA |

# Índice

**1. Introducción** **4**

1.1 Objeto y contexto del documento
1.2 Objetivos del Plan de Continuidad TIC
1.3 Ámbito de aplicación

**2. Análisis de Impacto en el Negocio (BIA)** **6**

2.1 Identificación de activos TIC con RTA y RPA
2.2 Servicios TIC críticos y dependencias con activos
2.3 RTA y RPA por servicio TIC
2.4 Procesos de negocio y MTD
2.5 RTO y RPO objetivo por servicio TIC
2.6 Análisis de GAPs

**3. Estrategia de Continuidad** **13**

**4. Escenarios de Contingencia** **14**

4.1 Caída de la conexión a Internet
4.2 Caída del ERP

**5. Plan de Crisis** **18**

5.1 Condiciones de disparo
5.2 Roles y responsabilidades
5.3 Contactos relevantes
5.4 Infraestructura disponible
5.5 Flujo de toma de decisiones

**6. Pruebas Periódicas** **22**

**7. Formación y Concienciación** **23**

# 1. Introducción

## 1.1 Objeto y contexto del documento

XYZ S.L. es una empresa logística mediana con sede en España que presta servicios de envío, recepción y almacenamiento de paquetería a clientes en diferentes puntos del mundo. Con aproximadamente 60 empleados y una operativa que depende en gran medida de sus sistemas de información —en particular del ERP SAP Business One y de la plataforma Microsoft 365—, la organización es vulnerable a interrupciones tecnológicas que podrían comprometer tanto su capacidad operativa como su imagen ante clientes.

En octubre del año anterior, un corte eléctrico de cuatro horas dejó a los repartidores coordinándose por teléfono y a administración sin poder emitir albaranes. Ese incidente, aunque contenido gracias a su corta duración, evidenció la ausencia de procedimientos formales de respuesta ante contingencias TIC. Desde entonces, la nueva gerencia ha invertido en seguridad de la información: se han aprobado Políticas de Seguridad (PSI_XYZ_v1.1), un Análisis de Riesgos (Informe_AR_XYZ_v1.0), un Plan Director de Seguridad (PDS_XYZ_v1.0), un Plan de Respuesta ante Incidentes (PRI_XYZ_v1.0) y se han completado auditorías internas bajo ISO 27001 y ENS. El presente documento cierra el cuerpo normativo de seguridad cubriendo la brecha que la auditoría ISO 27001 identificó en el control A17.1.1: la ausencia de un Plan de Continuidad TIC formal.

El Plan de Continuidad TIC (PCTIC) es el documento que establece cómo XYZ S.L. responderá ante interrupciones significativas de sus sistemas de información, con el objetivo de garantizar que los procesos de negocio críticos puedan continuar o recuperarse en tiempos aceptables. A diferencia del PRI, que se centra en la respuesta técnica ante incidentes de ciberseguridad, el PCTIC adopta una perspectiva más amplia: contempla tanto fallos técnicos como contingencias de conectividad, y establece la estrategia de recuperación desde el punto de vista del negocio.

## 1.2 Objetivos del Plan de Continuidad TIC

El presente plan persigue los siguientes objetivos:

- Establecer y documentar las instrucciones y directrices necesarias para contrarrestar las interrupciones de los sistemas TIC y garantizar su rápida reanudación, minimizando el impacto sobre los procesos de negocio de XYZ S.L.
- Identificar los activos TIC críticos y sus tiempos reales de recuperación (RTA y RPA), los servicios TIC que los sustentan y los procesos de negocio que dependen de ellos.

- Determinar los tiempos objetivo de recuperación (RTO y RPO) que el negocio considera aceptables para cada servicio, y analizar los GAPs existentes entre la capacidad actual y dichos objetivos.
- Definir procedimientos concretos de actuación para los escenarios de contingencia más relevantes: caída de la conexión a Internet y caída del ERP.
- Establecer un Plan de Crisis con roles, responsabilidades, contactos y flujos de decisión claros para que, cuando ocurra una contingencia, nadie tenga que improvisar.
- Fijar una periodicidad de pruebas y simulacros que permita verificar la efectividad del plan y detectar desviaciones antes de que se produzca una emergencia real.

## 1.3 Ámbito de aplicación

El presente plan es de aplicación a todos los empleados y terceros que realicen alguna actividad o proceso dentro de XYZ S.L. relacionado con los sistemas de información incluidos en el alcance. Por indicación expresa del enunciado, y para mantener el plan en un nivel de complejidad manejable en esta primera versión, no se contemplan en este documento aspectos de continuidad relacionados con el personal, los proveedores ni las ubicaciones físicas alternativas, que podrán incorporarse en versiones futuras del plan.

En términos de activos y sistemas, el ámbito abarca todos los elementos TIC que dan soporte a los dos procesos de negocio principales de la compañía: la gestión de pedidos de paquetería y la gestión del almacén. A nivel tecnológico, esto incluye los ordenadores portátiles de los usuarios, el correo electrónico corporativo (Microsoft 365), la conexión a Internet y la red Wi-Fi, el servidor de ficheros en cloud, el CPD con sus servidores (Active Directory y ERP SAP Business One).

# 2. Análisis de Impacto en el Negocio (BIA)

El BIA (Business Impact Analysis) es el punto de partida de cualquier plan de continuidad. Su objetivo es determinar qué ocurre —y durante cuánto tiempo puede ocurrir— si un sistema o servicio deja de estar disponible. Para XYZ S.L., la elaboración del BIA ha partido del conocimiento acumulado en el Análisis de Riesgos (Informe_AR_XYZ_v1.0) y de entrevistas con Marta López (CISO) y Juan Pérez (Responsable de IT), quienes han validado tanto los activos identificados como los tiempos estimados de recuperación.

El proceso se ha estructurado en seis pasos sucesivos: identificación de activos TIC con sus tiempos reales de recuperación (RTA y RPA); mapeado de dependencias entre activos y servicios TIC; cálculo de RTA y RPA por servicio; definición de procesos de negocio y sus tiempos máximos de indisponibilidad (MTD); establecimiento de los objetivos de recuperación (RTO y RPO); y, finalmente, análisis de los GAPs entre la capacidad actual del sistema y las necesidades del negocio.

## 2.1 Identificación de activos TIC con RTA y RPA

El primer paso consiste en identificar todos los activos TIC relevantes para la continuidad y calcular sus tiempos reales de recuperación. El RTA (Recovery Time Actual) es el tiempo que la infraestructura actual tarda en recuperar el activo en caso de fallo. El RPA (Recovery Point Actual) mide la pérdida real de datos cuando ocurre el desastre, determinado habitualmente por la antigüedad de la última copia de seguridad disponible. El RPA solo es aplicable a activos que cuenten con copia de seguridad.

Para cada activo se ha realizado una estimación basada en la infraestructura real de XYZ S.L. documentada en el Análisis de Riesgos: servidor HP ProLiant DL380 Gen9 como host del CPD, ERP SAP Business One v10.0 con dos VMs (aplicación y BBDD), Microsoft 365 como plataforma de correo y ficheros en cloud, y backup cloud con política de copia diaria nocturna.

| Activo TIC | Ubicación | ¿Backup? | RTA | RPA | Justificación |
|---|---|---|---|---|---|
| Ordenadores portátiles | Distribuidos / teletrabajo | No (datos en cloud) | 4 h | N/A | Sustitución por equipo de repuesto disponible en oficina o acceso temporal desde dispositivo móvil. Los datos de trabajo residen en el servidor cloud y en el ERP, no en local. |
| Correo electrónico (Microsoft 365) | Cloud (Microsoft) | Sí (Microsoft) | 1 h | 4 h | Servicio cloud con SLA del 99,9 %. Disponible desde cualquier dispositivo con conexión a Internet. Microsoft garantiza recuperación de elementos eliminados hasta 30 días. RPO efectivo inferior a 4 h. |

| Activo TIC | Ubicación | ¿Backup? | RTA | RPA | Justificación |
|---|---|---|---|---|---|
| Conexión Wi-Fi oficina | Sede principal | No | 4 h | N/A | Posible restablecimiento mediante segunda línea de Internet (proveedor 2) o punto de acceso móvil. No almacena datos. |
| Servidor de ficheros (cloud) | Cloud | Sí (cloud diario) | 2 h | 8 h | Servicio restaurable desde backup cloud diario. El RTA de 2 h incluye tiempo de contacto con soporte y restauración. El backup nocturno implica pérdida máxima de 8 h de trabajo. |
| CPD (infraestructura física) | Sede principal | No (física) | 48 h | N/A | En caso de daño físico total del CPD (incendio, inundación), la contratación de infraestructura alternativa requeriría al menos 48 h. No almacena datos per se. |
| Servidor AD (Active Directory) | CPD – sede principal | Sí (cloud diario) | 12 h | 24 h | Restauración desde backup cloud: aprovisionamiento de VM en el hipervisor más restauración de imagen del AD. Estimación conservadora: ~12 h. Backup nocturno implica pérdida máxima de 24 h. |
| ERP (SAP Business One v10.0) | CPD – sede principal | Sí (cloud diario) | 24 h | 24 h | El ERP se compone de dos VMs en el mismo host físico (servidor de aplicación + servidor de BBDD). Por restricción técnica del fabricante, ambas VMs deben restaurarse secuencialmente: primero el servidor de aplicación (~12 h) y después el de BBDD (~12 h adicionales). Total: 24 h. Backup nocturno: RPO 24 h. |

Es importante destacar el caso del ERP: a diferencia del resto de activos, sus dos componentes (servidor de aplicación y servidor de base de datos) son máquinas virtuales alojadas en el mismo host físico y, por restricciones del fabricante, no pueden arrancarse en paralelo. Esto eleva el RTA total del ERP a 24 horas, frente a las 12 horas que correspondería si la restauración pudiera realizarse en paralelo. Este dato es clave para la valoración de los GAPs que se realizará más adelante.

## 2.2 Servicios TIC críticos y dependencias con activos

Una vez identificados los activos, el siguiente paso consiste en agruparlos en servicios TIC y mapear las dependencias. Un servicio TIC es la capacidad funcional que la tecnología ofrece al negocio; cada servicio puede depender de uno o varios activos. Para XYZ S.L. se han identificado tres servicios TIC críticos:

| Servicio TIC | Ordenadores portátiles | Correo electrónico | Wi-Fi / Internet | Servidor ficheros (cloud) | Servidor AD | ERP (SAP B1) |
|---|---|---|---|---|---|---|
| Servicio de comunicación | X | X | X | | X | |
| Servicio de ficheros | X | | X | X | X | |
| Servicio de ERP | X | | X | | X | X |

El servicio de comunicación engloba el correo electrónico y la capacidad de los usuarios de acceder a los sistemas desde cualquier ubicación, lo que lo hace dependiente también de la conectividad a Internet. El servicio de ficheros requiere tanto la conectividad como el servidor AD para la autenticación de los usuarios al acceder a los documentos corporativos. El servicio de ERP es el más complejo: además del propio ERP, requiere que los portátiles estén operativos, que haya conectividad y que el AD esté disponible para autenticar a los usuarios que acceden a la aplicación.

## 2.3 RTA y RPA por servicio TIC

El RTA y el RPA de cada servicio TIC se calculan como el valor más alto de los activos de los que depende, asumiendo que las acciones de recuperación de distintos activos pueden ejecutarse en paralelo. En el caso del ERP, dado que sus dos VMs deben restaurarse secuencialmente, el RTA ya incorpora esa suma en el propio activo (24 h), por lo que no es necesario agregar tiempos adicionales a nivel de servicio.

| Servicio TIC | Activos involucrados | RTA del servicio | Justificación RTA | RPA del servicio | Justificación RPO |
|---|---|---|---|---|---|
| Servicio de comunicación | Portátiles, Correo (M365), Internet/Wi-Fi, AD | 4 h | El activo más lento del servicio son los portátiles y la Wi-Fi (4 h). El correo cloud se recupera en 1 h. | 4 h | El correo tiene RPO de 4 h. El AD tiene RPO de 24 h pero no implica pérdida de correos. |
| Servicio de ficheros | Portátiles, Internet/Wi-Fi, Servidor ficheros cloud, AD | 8 h | El activo más lento es el servidor de ficheros cloud (2 h RTA) combinado con la Wi-Fi (4 h). El RPA del servicio lo marca el servidor de ficheros: 8 h. | 8 h | El servidor de ficheros tiene backup nocturno. Pérdida máxima: datos del día en curso (8 h). |
| Servicio de ERP | Portátiles, Internet/Wi-Fi, AD, ERP (SAP B1) | 24 h | El ERP marca el RTA del servicio (24 h, restauración secuencial de las dos VMs). El resto de activos tienen RTA inferior. | 24 h | Backup nocturno del ERP. Pérdida máxima: transacciones del día en curso. |

## 2.4 Procesos de negocio y MTD

Los procesos de negocio son las actividades que XYZ S.L. lleva a cabo para prestar sus servicios de logística. Para cada uno de ellos se define el MTD (Maximum Tolerable Downtime), es decir, el tiempo máximo que ese proceso puede estar paralizado sin causar consecuencias inaceptables para la organización. El MTD ha sido definido en colaboración con los responsables de las áreas de negocio y representa el límite a partir del cual la indisponibilidad empieza a tener impacto financiero, reputacional o contractual severo.

| Proceso de negocio | Departamento | Serv. Comunicación | Serv. Ficheros | Serv. ERP | MTD | Justificación MTD |
|---|---|---|---|---|---|---|
| Gestión de pedidos de paquetería | Operaciones | X | X | X | 24 h | Pasadas 24 h sin ERP, no pueden gestionarse albaranes, asignación de rutas ni confirmaciones de entrega. El incumplimiento de SLAs con clientes comenzaría a tener consecuencias contractuales. |
| Gestión de almacén | Almacén | X | X | X | 24 h | El sistema de gestión de stock depende del ERP. Sin él, el inventario debe gestionarse manualmente, proceso que se vuelve inasumible superadas 24 h. |
| Gestión de nóminas | Administración | X | X | X | 72 h | Las nóminas tienen ciclo mensual. Una interrupción inferior a 72 h no afecta directamente a los pagos, aunque sí dificulta la gestión administrativa. |
| Comunicación interna y con clientes | Todos | X | | | 8 h | El correo electrónico es el canal principal de comunicación con clientes y proveedores. Pasadas 8 h sin correo, la operativa se ve gravemente comprometida. |

## 2.5 RTO y RPO objetivo por servicio TIC

Los RTO (Recovery Time Objective) y RPO (Recovery Point Objective) son los tiempos objetivo que el negocio considera aceptables para la recuperación de cada servicio en caso de contingencia. A diferencia del RTA y el RPA, que miden la capacidad actual del sistema, el RTO y el RPO reflejan la exigencia del negocio. Estos valores han sido determinados por los responsables de cada área funcional, teniendo en cuenta los MTD de los procesos que dependen de cada servicio.

La regla de derivación es la siguiente: el RTO de un servicio no puede superar el MTD del proceso de negocio más crítico que depende de él. Si lo supera, existe un GAP que debe resolverse.

| Servicio TIC | RTO (objetivo negocio) | RPO (objetivo negocio) | Fuente / Justificación |
|---|---|---|---|
| Servicio de comunicación | 8 h | 4 h | El proceso de comunicación con clientes tiene un MTD de 8 h. El correo es el canal principal. El negocio acepta perder hasta 4 h de correos en un escenario de desastre. |
| Servicio de ficheros | 12 h | 8 h | El acceso a documentos es necesario para la gestión de pedidos y almacén. El negocio acepta hasta 12 h sin acceso a ficheros antes de que impacte gravemente a las operaciones. |
| Servicio de ERP | 24 h | 24 h | El ERP está vinculado a procesos con MTD de 24 h. El negocio acepta como máximo 24 h sin ERP y la pérdida de las transacciones del día en curso. |

## 2.6 Análisis de GAPs

El análisis de GAPs compara los tiempos reales de recuperación del sistema (RTA y RPA) con los objetivos fijados por el negocio (RTO y RPO). Cuando el RTA es mayor que el RTO, o el RPA es mayor que el RPO, existe un GAP que debe ser atendido.

| Servicio TIC | RTA actual | RTO objetivo | GAP RTA | RPA actual | RPO objetivo | GAP RPA | ¿Cubr |
|---|---|---|---|---|---|---|---|
| Serv. comunicación | 4 h | 8 h | No (4 < 8) | 4 h | 4 h | No (4 = 4) | ✓ SÍ |
| Serv. ficheros | 8 h | 12 h | No (8 < 12) | 8 h | 8 h | No (8 = 8) | ✓ SÍ |
| Serv. ERP | 24 h | 24 h | No (24 = 24) | 24 h | 24 h | No (24 = 24) | ✓ SÍ (ajusta |

| **CONFORME \| Sin GAPs críticos en la configuración actual** |
| --- |
| El análisis de GAPs concluye que, con la configuración y los procedimientos descritos en este plan, la capacidad actual de los sistemas de XYZ S.L. cubre los objetivos de recuperación fijados por el negocio. El servicio de comunicación y el de ficheros presentan margen positivo (el RTA es inferior al RTO), mientras que el ERP es el caso más ajustado: el RTA y el RTO coinciden exactamente en 24 h, lo que no deja margen de maniobra. |
| Esta situación es aceptable pero frágil: cualquier complicación durante la restauración del ERP (por ejemplo, un problema con el backup o un fallo adicional en el hardware) podría traducirse en un GAP real. Por este motivo, en la sección de estrategia de continuidad se recomienda explorar la contratación de un servidor físico de backup en el CPD que permita reducir el RTA del ERP a 12 h mediante restauración paralela de las VMs, o la migración del ERP a una plataforma cloud con opciones de alta disponibilidad.<br><br>En cualquier caso, la resolución de estos GAPs potenciales no es alcance de este PCTIC v1.0, sino que se trasladará al Plan Director de Seguridad como iniciativa prioritaria para el año 2 del horizonte 2026-2028. |

# 3. Estrategia de Continuidad

Con la información del BIA disponible —activos identificados, dependencias mapeadas, tiempos calculados y GAPs analizados—, el siguiente paso es determinar qué estrategias de recuperación se adoptarán para cada escenario de contingencia. La estrategia no es única para todos los activos: depende del tipo de fallo, de la criticidad del servicio afectado y del tiempo disponible para la recuperación.

Para XYZ S.L., dado su tamaño y la naturaleza de su infraestructura, la estrategia se articula sobre los siguientes pilares:

- Redundancia de conectividad a Internet: la empresa contratará un segundo proveedor de Internet (proveedor 2) con conmutación automática configurada en el router perimetral, de forma que si el proveedor principal cae, el tráfico se desvíe de forma automática en menos de 15 minutos. Como tercer nivel de respaldo, los gestores con dispositivos móviles de empresa pueden compartir su conexión de datos para mantener acceso al correo y al servidor de ficheros cloud.
- Backup cloud diario para activos del CPD: el servidor AD y las VMs del ERP disponen de backup cloud con política de copia nocturna. Este backup es la base de la estrategia de recuperación ante fallo del CPD y está documentado en el PRI_XYZ_v1.0. Para reforzar la fiabilidad, se realizarán pruebas de restauración trimestrales (ver sección 6).
- Servidor físico de backup en el CPD: a corto plazo, y para reducir el RTA del ERP en un escenario de fallo del host principal, se evaluará la adquisición de un servidor físico de backup preconfigurado que permita arrancar las VMs del ERP en paralelo, reduciendo el RTA total de 24 h a 12 h. Esta iniciativa se contempla en el PDS_XYZ_v1.0 como proyecto del año 2.
- Uso de dispositivos móviles como respaldo de conectividad: los usuarios con dispositivos móviles de empresa pueden, mientras dure la contingencia de Internet, acceder al correo desde su aplicación móvil y comunicarse con clientes mediante datos móviles, garantizando un nivel mínimo de operatividad durante las primeras horas.
- Procedimientos manuales de emergencia: para el proceso de gestión de pedidos, se documentará un procedimiento de trabajo manual en papel para las primeras horas de una contingencia del ERP, que permita registrar las recepciones y entregas más urgentes sin acceso al sistema. Este procedimiento será elaborado por el equipo de Operaciones y revisado anualmente.

La estrategia no contempla, en esta primera versión, la contratación de una ubicación alternativa ni la gestión de la continuidad del personal, elementos que se incorporarán en la revisión del plan prevista para el año 2 del PDS.

# 4. Escenarios de Contingencia

Los escenarios de contingencia definen qué situaciones concretas activan el presente plan y qué pasos deben seguirse para gestionarlas. Para cada escenario se describe la situación que lo origina, los servicios afectados y los tiempos asociados (RTA, RPA, RTO, RPO), y se detallan los pasos de actuación. Por indicación del enunciado, este plan contempla dos escenarios en su versión inicial.

## 4.1 Caída de la conexión a Internet

Este escenario se refiere a la pérdida total o parcial del acceso a Internet desde la oficina principal de XYZ S.L., ya sea por un fallo del proveedor 1, por un problema en el equipamiento de red perimetral (router, firewall FortiGate 60F) o por una incidencia en el bucle local. La caída de Internet afecta directamente a los servicios que dependen de conectividad externa: el correo electrónico (Microsoft 365), el servidor de ficheros cloud y la VPN de acceso remoto para teletrabajadores.

| **ESCENARIO DE CONTINGENCIA \| EC-01 \| Caída de la conexión a Internet** |
|---|
| Servicios afectados: Servicio de comunicación (correo electrónico) y Servicio de ficheros (servidor cloud). El ERP, el AD y los equipos locales no se ven afectados directamente mientras funcionen en la red local.<br><br>RTA del escenario: 4 horas (tiempo estimado para activar la conexión redundante con el proveedor 2 o los datos móviles). En condiciones ideales, con la conmutación automática configurada, el tiempo de corte efectivo puede reducirse a menos de 15 minutos.<br><br>RPA del escenario: 4 horas (correo electrónico, marcado por la política de backup de Microsoft 365). |
| RTO del escenario: 8 horas (fijado por el MTD del proceso de comunicación con clientes, que es el más restrictivo de los procesos afectados).<br><br>RPO del escenario: 4 horas.<br><br>Resultado: el RTA (4 h) es inferior al RTO (8 h). No existe GAP, pero la brecha es limitada y depende de que la redundancia esté correctamente configurada y probada. |

### Procedimiento de actuación

En el momento en que se detecta la pérdida de conectividad a Internet, el primer paso es verificar que se trata de un fallo del proveedor y no de un problema interno de la red. Juan Pérez (Responsable de IT) o el personal técnico designado accederá a la consola de administración del FortiGate 60F para confirmar si el enlace WAN principal está caído y si el router del proveedor 1 es accesible.

- Paso 1 — Detección y verificación (0-15 min): El primer usuario que detecta la pérdida de Internet lo notifica a Juan Pérez o, en su ausencia, a Marta López. Se verifica en la consola del

FortiGate 60F si el enlace WAN principal está inactivo. Si el problema es de la red interna (switch, AP), se actúa sobre el equipamiento interno. Si el problema es del proveedor, se pasa al paso 2.

- Paso 2 — Activación de la conexión redundante (15-60 min): Si el router dispone de conmutación automática configurada con el proveedor 2, la transición habrá ocurrido ya de forma automática. En caso contrario, Juan Pérez configurará manualmente la salida por el proveedor 2. Se verifica que el acceso al correo, al servidor de ficheros y a la VPN es operativo a través de la conexión alternativa.
- Paso 3 — Notificación al proveedor 1 (0-30 min, en paralelo): Se contacta con el servicio de averías del proveedor 1 para reportar la incidencia y obtener un tiempo estimado de resolución. Los datos de contacto se encuentran en la tabla de contactos de la sección 5.3.
- Paso 4 — Comunicación interna (60 min): Marta López notifica a los responsables de área el estado de la incidencia y el tiempo estimado de restauración del enlace principal. Los teletrabajadores son informados de que pueden usar datos móviles como respaldo si la VPN no está disponible.
- Paso 5 — Monitorización y cierre (continuo hasta resolución): Se mantiene monitorización del estado del enlace principal. Una vez restaurado, se verifica que todos los servicios han vuelto a operar correctamente a través del proveedor 1 y se registra el incidente con su duración y el procedimiento seguido.

Si la caída de Internet supera las 4 horas sin perspectiva de resolución, se considera la activación del Plan de Crisis (ver sección 5) y se evalúa si es necesario comunicar la incidencia a clientes afectados.

## 4.2 Caída del ERP

Este escenario contempla cualquier fallo o anomalía que impida el acceso normal a la aplicación ERP SAP Business One v10.0, ya sea por un fallo del host físico (servidor HP ProLiant DL380 Gen9), por corrupción de la base de datos, por fallo de una de las dos VMs, o por un error grave de la aplicación. Dado que el ERP es el sistema central de gestión de pedidos, almacén y nóminas de XYZ S.L., su caída es el escenario de contingencia de mayor impacto para la operativa del negocio.

| **ESCENARIO DE CONTINGENCIA \| EC-02 \| Caída del ERP** |
|---|
| Servicios afectados: Servicio de ERP. También puede afectar al Servicio de ficheros si el fallo es del host físico completo, que aloja también los backups locales.<br><br>RTA del escenario: 24 horas (restauración secuencial de las dos VMs: servidor de aplicación ~12 h, seguido de servidor de BBDD ~12 h adicionales. No pueden restaurarse en paralelo por restricción del fabricante). |
| RPA del escenario: 24 horas (backup nocturno diario. Las transacciones del día en curso se pierden y deben reanudarse manualmente desde los registros físicos o comunicaciones de correo). |

| |
|---|
| RTO del escenario: 24 horas (fijado por el MTD de los procesos de gestión de pedidos y gestión de almacén, que es de 24 h). |
| RPO del escenario: 24 horas. |
| MTD del escenario: 24 horas (determinado por el proceso más crítico dependiente del ERP: gestión de pedidos y gestión de almacén). Pasadas 24 h sin ERP operativo, el impacto sobre los SLAs con clientes sería inaceptable.<br><br>Resultado: el RTA (24 h) es igual al RTO (24 h). No existe GAP técnico, pero el margen es nulo. Cualquier complicación durante la restauración convertiría este escenario en un incumplimiento del RTO. |

## Procedimiento de actuación

En el momento en que se detecta que el ERP no responde o presenta errores graves que impiden su uso, Juan Pérez evalúa si se trata de un problema puntual de aplicación (reinicio de servicio) o de un fallo del host físico o de las VMs que requiere restauración completa desde backup. La declaración formal de contingencia se produce si, pasados 30 minutos desde la detección, el ERP no ha podido restaurarse por medios ordinarios.

- Paso 1 — Detección y diagnóstico inicial (0-30 min): El primer usuario que detecta el problema lo notifica a Juan Pérez. Se intenta un reinicio controlado del servicio SAP y de las VMs afectadas desde la consola del hipervisor. Si el problema persiste, se declara contingencia EC-02 y se activa el plan.
- Paso 2 — Activación del plan de contingencia y comunicación interna (30-60 min): Marta López notifica a la Dirección y a los responsables de área que el ERP no está disponible. Se activan los procedimientos manuales de emergencia: los equipos de operaciones y almacén inician el registro manual de entradas, salidas y pedidos en los formularios en papel habilitados para estos casos.
- Paso 3 — Preparación del entorno de restauración (1-4 h): Juan Pérez accede al sistema de backup cloud y verifica la integridad de la última imagen disponible del servidor de aplicación del ERP. Se prepara el entorno del hipervisor (o, si el host físico ha fallado completamente, se enciende la máquina física de backup disponible en el CPD y se prepara el entorno de virtualización).
- Paso 4 — Restauración del servidor de aplicación (4-12 h): Se restaura la imagen del servidor de aplicación SAP Business One desde el backup cloud. Una vez completada la restauración, se verifica que el servidor arranca correctamente y que los servicios de la aplicación responden.
- Paso 5 — Restauración del servidor de base de datos (12-24 h): Una vez que el servidor de aplicación está operativo, se inicia la restauración del servidor de BBDD desde su imagen de

backup. Este paso debe ejecutarse después del de aplicación: arrancarlos en orden inverso provoca inconsistencias en la base de datos.

- Paso 6 — Verificación y vuelta a la normalidad (24 h): Se verifica el correcto funcionamiento del ERP realizando las operaciones básicas del día anterior: consulta de pedidos, gestión de stock y acceso a informes. Una vez validado, se notifica a todos los usuarios que el sistema está disponible. Los registros manuales del periodo de contingencia se vuelcan al ERP de forma coordinada con los responsables de área.
- Paso 7 — Registro y análisis post-incidente (24-48 h tras la restauración): Juan Pérez y Marta López elaboran un informe post-incidente documentando la causa raíz, el tiempo real de restauración, las incidencias ocurridas durante el proceso y las lecciones aprendidas. Este informe se archiva como evidencia y se revisa en la próxima reunión de seguimiento del PCN.

Si transcurridas 24 horas desde la activación del plan el ERP no ha podido ser restaurado, se activa el nivel máximo del Plan de Crisis. En ese punto, la Dirección debe decidir si se contrata un servicio de CPD externo de emergencia o si se acuerda con los clientes afectados una prórroga temporal de los SLAs.

# 5. Plan de Crisis

El Plan de Crisis define los mecanismos de gestión de las primeras horas de una contingencia: quién decide, quién ejecuta, quién comunica y en qué orden. Su propósito es evitar que, cuando ocurra un incidente real, las decisiones se tomen de forma improvisada o contradictoria. Los primeros 30-60 minutos de una contingencia son los más críticos y los que más condicionan el tiempo total de recuperación.

## 5.1 Condiciones de disparo

Se considera que existe una situación de crisis TIC —y por tanto se activa el presente plan— cuando se cumple alguna de las siguientes condiciones:

- La conexión a Internet de la oficina principal lleva más de 30 minutos inactiva y no se ha restaurado por medios ordinarios, o la interrupción se prevé superior a 4 horas.
- El ERP no está disponible tras 30 minutos desde la detección del fallo, o el diagnóstico inicial indica un fallo del host físico o de las VMs que requiere restauración desde backup.
- Cualquier otro servicio TIC crítico (AD, servidor de ficheros) lleva más tiempo caído que su RTA estimado sin perspectiva de resolución inmediata.
- Se supera el MTD de cualquier proceso de negocio crítico sin que el servicio afectado haya sido restaurado.

La declaración formal de crisis la realiza Marta López (CISO) en coordinación con Juan Pérez (IT). En ausencia de ambos, la declaración la realiza la Dirección.

## 5.2 Roles y responsabilidades

Durante una contingencia TIC, cada persona tiene un rol definido. No se toman decisiones fuera del rol asignado sin autorización explícita del nivel superior. Esto es especialmente importante en los primeros momentos, cuando la presión tiende a provocar actuaciones no coordinadas.

| Rol | Responsable | Funciones durante la contingencia |
|---|---|---|
| Director/a General (Dirección) | Gerencia General | Autoriza medidas extraordinarias con impacto económico (contratación de infraestructura de emergencia, comunicación a clientes estratégicos). Aprueba la declaración de crisis si CISO e IT no están disponibles. Recibe informes de situación cada 4 horas. |
| CISO / Responsable de Seguridad | Marta López | Declara y lidera la gestión de la crisis. Coordina las comunicaciones internas y externas. Supervisa que se cumplen los procedimientos del PCN. Mantiene el registro de eventos del incidente. Informa a Dirección del estado cada 4 horas. |

| Rol | Responsable | Funciones durante la contingencia |
|---|---|---|
| Responsable de IT | Juan Pérez | Ejecuta los procedimientos técnicos de recuperación definidos en los escenarios de contingencia. Gestiona la relación con proveedores técnicos (ISP, soporte SAP, backup cloud). Informa a CISO del estado técnico en tiempo real. |
| Administrador de sistemas | Marcos (IT) | Apoya a Juan Pérez en la ejecución de los procedimientos técnicos. Monitoriza los sistemas durante la recuperación. En ausencia de Juan Pérez, asume sus responsabilidades técnicas. |
| Responsables de área | Resp. Operaciones / Almacén / Admin. | Activan los procedimientos manuales de emergencia en sus áreas. Informan a CISO de las necesidades urgentes del negocio. Coordinan el volcado de datos manuales al sistema cuando este se restaura. |
| Usuarios | Todos los empleados | Siguen las instrucciones de la Dirección y de la CISO. No toman iniciativas técnicas. Reportan cualquier anomalía adicional que detecten al Responsable de IT. |

## 5.3 Contactos relevantes

La siguiente tabla recoge los contactos clave para la gestión de una contingencia TIC. Esta información debe estar accesible en formato físico (impreso y almacenado en la caja de contingencias del CPD) y en formato digital offline en los dispositivos móviles de Marta López y Juan Pérez.

### Contactos internos

| Nombre | Cargo | Teléfono | Correo | Disponibilidad |
|---|---|---|---|---|
| Marta López | CISO / Resp. Seguridad | 600 111 222 | mlopez@xyz-sl.es | 24/7 en contingencia |
| Juan Pérez | Resp. IT | 600 333 444 | jperez@xyz-sl.es | 24/7 en contingencia |
| Marcos García | Administrador sistemas | 600 555 666 | mgarcia@xyz-sl.es | Horario laboral + guardia |
| Gerencia General | Director/a General | 600 777 888 | gerencia@xyz-sl.es | 24/7 en contingencia |

### Contactos externos y proveedores

| Proveedor / Servicio | Contacto | Teléfono de averías | Nº de contrato | SLA de respuesta |
|---|---|---|---|---|
| ISP Proveedor 1 (Internet principal) | Servicio de averías empresas | 900 100 200 | XYZ-ISP1-2024 | 4 h (horario laboral) / 8 h (festivos) |
| ISP Proveedor 2 (Internet redundante) | Servicio de averías empresas | 900 300 400 | XYZ-ISP2-2025 | 4 h (horario laboral) |
| Soporte SAP Business One | Partner SAP certificado | 91 500 600 0 | SAP-XYZ-B1-2023 | NBD (Next Business Day) |

| Proveedor / Servicio | Contacto | Teléfono de averías | Nº de contrato | SLA de respuesta |
|---|---|---|---|---|
| Backup cloud (proveedor) | Soporte técnico | 900 700 800 | XYZ-BCK-2024 | 2 h (criticidad alta) |
| Seguridad privada edificio | Central de alarmas | 91 900 100 0 | SEC-EDIF-2022 | Respuesta in situ <30 min |

## 5.4 Infraestructura disponible para la contingencia

La siguiente tabla recoge los elementos de infraestructura disponibles en XYZ S.L. que pueden ser activados durante una contingencia, junto con su función y el responsable de su activación.

| Recurso | Función en contingencia | Ubicación | Responsable de activación |
|---|---|---|---|
| Conexión Internet proveedor 2 | Línea de Internet redundante para EC-01 | CPD – router perimetral | Juan Pérez |
| Datos móviles (dispositivos empresa) | Acceso a correo y ficheros cloud en ausencia de Wi-Fi | Distribuido (usuarios con móvil) | Marta López (instrucción a usuarios) |
| Servidor físico de backup (CPD) | Host alternativo para levantar VMs del ERP en EC-02 | CPD – sede principal | Juan Pérez / Marcos García |
| Backup cloud (imágenes VMs) | Fuente de restauración de AD y ERP | Cloud (proveedor backup) | Juan Pérez |
| Formularios manuales de emergencia | Registro manual de pedidos y movimientos de almacén durante caída del ERP | Almacén y mostrador operaciones | Resp. Operaciones / Resp. Almacén |
| Caja de contingencias física | Documentación impresa del PCN, contraseñas en sobre sellado, contactos de emergencia | CPD – armario bajo llave | Marta López |

## 5.5 Flujo de toma de decisiones

El flujo de toma de decisiones durante una contingencia sigue la cadena de mando establecida. El objetivo es que cada decisión sea tomada por la persona con la autoridad y el conocimiento adecuados, y que ninguna decisión relevante quede sin responsable asignado.

| Situación | ¿Quién decide? | ¿Quién ejecuta? | ¿Quién comunica? |
|---|---|---|---|
| Detección inicial de anomalía | Juan Pérez (diagnóstico técnico) | Juan Pérez / Marcos | Juan Pérez → Marta López |
| Declaración de contingencia (< 4 h estimadas) | Marta López | Juan Pérez / Marcos | Marta López → responsables de área |

| Situación | ¿Quién decide? | ¿Quién ejecuta? | ¿Quién comunica? |
|---|---|---|---|
| Declaración de crisis (> 4 h o MTD en riesgo) | Marta López + Dirección | Juan Pérez / Marcos | Marta López → todos + clientes si aplica |
| Activación de infraestructura de emergencia | Juan Pérez | Juan Pérez / Marcos | Juan Pérez → Marta López |
| Contratación de servicio externo de emergencia | Dirección (autorización económica) | Juan Pérez (ejecución técnica) | Dirección → Marta López |
| Declaración de fin de contingencia | Marta López | Juan Pérez (verificación técnica) | Marta López → todos los usuarios |

# 6. Pruebas Periódicas

Un plan de continuidad que nunca se prueba es, en la práctica, un documento de confianza ciega. Los tiempos de recuperación estimados en el BIA se basan en condiciones ideales: backup íntegro, hardware funcional, personal disponible y procedimientos bien ejecutados. La realidad de una contingencia rara vez es tan ordenada. Por eso, las pruebas periódicas son la parte más importante del ciclo de vida del PCN: permiten verificar que los tiempos son reales, detectar problemas que no se habían anticipado y mantener al equipo técnico entrenado en los procedimientos.

El programa de pruebas de XYZ S.L. se estructura en dos tipos de actividades con periodicidades distintas:

## Pruebas técnicas de restauración (trimestral)

Con carácter trimestral, el equipo de IT realizará una prueba de restauración completa de las imágenes de backup del servidor AD y del servidor de aplicación del ERP. La prueba consistirá en restaurar la imagen más reciente disponible en un entorno de test aislado (sin afectar al sistema en producción) y verificar que el sistema arranca correctamente y que los datos son accesibles e íntegros. El resultado de cada prueba se documentará en un informe breve que recoja la fecha, el tiempo real de restauración, cualquier incidencia detectada y las acciones correctivas adoptadas.

Estas pruebas son especialmente críticas para el escenario EC-02 (caída del ERP), ya que el RTA de 24 horas asume que el backup está íntegro y que el proceso de restauración se ejecuta sin complicaciones. Si una prueba trimestral revela que el tiempo real de restauración supera las 24 horas, se activará una revisión urgente del procedimiento y se actualizará el BIA en consecuencia.

## Simulacro anual de contingencia

Una vez al año, en el primer trimestre, XYZ S.L. realizará un simulacro completo de al menos uno de los dos escenarios de contingencia definidos en este plan. El escenario se elegirá de forma alterna: el primer año se simulará la caída de Internet (EC-01) y el segundo la caída del ERP (EC-02). El simulacro incluirá la detección del incidente, la declaración de contingencia, la activación de los procedimientos de comunicación interna, la ejecución de los pasos técnicos de recuperación en un entorno controlado y el cierre formal del incidente.

El simulacro no interrumpirá la operativa de producción: se realizará fuera del horario laboral o sobre sistemas de test. Al finalizar, Marta López elaborará un informe de simulacro con los tiempos reales medidos, las desviaciones respecto al plan, las incidencias detectadas y las recomendaciones de mejora. Este informe se presentará a la Dirección y se incorporará al proceso de revisión anual del PCN.

| Tipo de prueba | Frecuencia | Responsable | Entregable |
|---|---|---|---|
| Prueba de restauración AD (backup cloud) | Trimestral | Juan Pérez / Marcos | Informe de prueba con tiempo real y resultado |
| Prueba de restauración ERP (backup cloud) | Trimestral | Juan Pérez / Marcos | Informe de prueba con tiempo real y resultado |
| Verificación de contactos del plan de crisis | Semestral | Marta López | Actualización de la tabla de contactos |
| Simulacro EC-01 (caída Internet) | Anual (años impares) | Marta López + Juan Pérez | Informe de simulacro presentado a Dirección |
| Simulacro EC-02 (caída ERP) | Anual (años pares) | Marta López + Juan Pérez | Informe de simulacro presentado a Dirección |
| Revisión completa del PCN | Anual (o tras cambio significativo) | Marta López | PCN actualizado y aprobado por Dirección |

# 7. Formación y Concienciación

Un plan de continuidad solo funciona si las personas que deben ejecutarlo lo conocen, lo comprenden y saben exactamente qué se espera de ellas cuando ocurre una contingencia. La formación no es un trámite burocrático: es la diferencia entre una respuesta coordinada que salva el negocio y un caos de decisiones contradictorias que lo hunde más.

El programa de formación y concienciación de XYZ S.L. en materia de continuidad TIC se estructura en tres niveles según el rol de cada persona:

### Nivel 1 — Dirección y responsables de área

La Dirección y los responsables de área recibirán una sesión anual de 2 horas en la que se revisará el estado del PCN, los resultados del simulacro del año anterior y cualquier cambio relevante en los procedimientos. El objetivo no es que comprendan los detalles técnicos, sino que entiendan cuándo deben activar el plan, qué decisiones les corresponden y cómo comunicar hacia sus equipos durante una contingencia. Esta sesión se realizará en el primer trimestre del año, tras el simulacro anual.

### Nivel 2 — Equipo técnico (IT)

Juan Pérez, Marcos García y el personal técnico de soporte participarán en las pruebas trimestrales de restauración, que tienen también un componente formativo: cada prueba es una oportunidad de ejecutar el procedimiento en condiciones controladas y detectar puntos de mejora. Adicionalmente, cuando se incorpore nuevo personal técnico, recibirá una sesión específica de onboarding sobre el PCN antes de asumir cualquier rol en la gestión de la infraestructura crítica.

### Nivel 3 — Usuarios generales

Todos los empleados de XYZ S.L. deben conocer qué hacer cuando detectan que un sistema no está disponible: a quién notificarlo, qué procedimientos manuales de emergencia activar en su área y qué no deben hacer (intentar soluciones técnicas por su cuenta, ignorar el problema, comunicar externamente sin autorización). Esta información se transmitirá a través de dos canales: una píldora formativa anual de 30 minutos incluida en el plan de formación de seguridad corporativo, y una tarjeta de referencia rápida (una hoja A5) con los pasos clave y los contactos de emergencia, disponible tanto en el portal de intranet como en formato físico en cada puesto de trabajo.

La Dirección pondrá el PCN a disposición de todo el personal a través del correo electrónico y de la intranet corporativa. Cualquier actualización del plan que afecte a procedimientos de usuario será comunicada expresamente mediante correo a todos los empleados, con acuse de recibo. Marta López llevará un registro de las sesiones formativas realizadas, las personas que han recibido la formación y la fecha, como evidencia del cumplimiento del programa.

| Actividad formativa | Destinatarios | Frecuencia | Responsable | Formato |
|---|---|---|---|---|
| Revisión del PCN y resultados del simulacro | Dirección + responsables área | Anual (Q1) | Marta López | Reunión presencial 2 h |
| Onboarding PCN personal técnico | Nuevas incorporaciones IT | Al incorporarse | Juan Pérez | Sesión práctica 4 h |
| Pruebas de restauración (formación práctica) | Equipo IT | Trimestral | Juan Pérez | Ejercicio técnico documentado |
| Píldora formativa continuidad TIC | Todos los empleados | Anual | Marta López | Sesión online 30 min |
| Tarjeta de referencia rápida | Todos los empleados | Permanente (actualización anual) | Marta López | Documento A5 físico + digital |